

특정감사

# 감 사 보 고 서

- 개인정보 및 정보보안 관리실태 특정감사 -

2024. 11.



공무원연금공단 감사실



## 목 차



|                           |    |
|---------------------------|----|
| I . 실시감사 개요 .....         | 1  |
| 1. 감사배경                   |    |
| 2. 기본방향 및 중점사항            |    |
| 3. 감사실시 과정                |    |
| 4. 감사결과 처리                |    |
| II . 감사결과 .....           | 2  |
| 1. 총 평                    |    |
| 2. 지적사항 총괄                |    |
| 3. 분야별 지적사항 [요약]          |    |
| 4. 지적사항에 대한 처리기준          |    |
| III . 감사결과 처분요구 일람표 ..... | 10 |
| IV . 감사결과 처분요구서 .....     | 10 |
| 【별 첨】 감사결과 처분요구서 .....    | 11 |

# I. 실지감사 개요

## 1. 감사배경

공단 「감사규정」 제4조제3항과 “○○○○년 연간 감사업무 계획 보고” (감사실-○○○○호, '○○. ○.○○.)에 따라 실시한 특정감사로서 공단 본부, 지부 및 자회사를 대상으로 전사적 개인정보 보호 및 정보보안 관리실태를 점검하였다.

## 2. 기본방향 및 중점사항

이번 감사에서는 본부, 지부, 자회사(○○○○○○○○○○○○○○○○○○○○)를 대상으로 「개인정보보호법」, 「국가 정보보안 지침」 등 관련법령 준수여부, 정보보안 관리 및 정보시스템 취약사항, 사용자 PC 보안관리의 적정성 등을 점검하여 개인정보보호 및 정보보안업무의 침해사고 위험요소를 최소화하기 위하여 개선사항을 발굴하는데 중점을 두었다.

## 3. 감사실시 과정

이번 감사는 ○명의 감사인력을 투입하여 실지감사에 필요한 기초자료를 수집하기 위해 ○○○○. ○○. ○○.부터 ○○. ○○.까지 ○일간의 예비조사와 ○○○○. ○○. ○○.부터 ○○. ○○.까지 ○○일간 실지감사를 실시하였다.

※ 감사일수(○○일) : ○○일×○명, ○일×○명(준감사인 ○일×○명, 내부전문가 ○○일×○명 제외)

## 4. 감사결과 처리

감사결과 시정·주의·권고 등이 필요한 사항은 업무처리 내용 및 경위를 확인한 후에 확인서를 징구하였고, 모든 지적사항에 대하여 해당 부서 담당자가 참석한 가운데 감사마감회의(○○○○. ○○. ○○.)를 통하여 의견을 수렴하였으며, 내부검토 및 감사결과심의회 심의(○○○○. ○○. ○○.)를 거쳐 감사 결과를 확정하였다.

## Ⅱ. 감사결과

### 1. 총 평

개인정보 및 정보보안 관리실태 특정감사는 「공공감사에 관한 법률」과 감사원 규칙 「공공감사기준」에 따라 시행하였으며, 우리 공단 「감사규정」에 의거하여 감사 결과를 보고하고, 이에 따라 조치하고자 한다.

금번 특정감사에서 개인정보 및 정보보안 관리실태와 관련한 중대한 오류 사항은 발견되지는 않았으나, 관련 법령 및 보안사항 미준수 등 일부 문제점이 확인되었다.

일부 부서 및 지부에서는 개인정보를 목적 외 이용하거나 제3자에게 제공하는 경우에는 관련 법령에 따라 관리대장을 작성 및 관리하여야 하며, 이 때, 정보주체의 동의를 받지 않은 경우에는 홈페이지에도 게시하여야 하나, 이를 미이행한 사실이 확인되었다.

그리고 공단 및 자회사는 「국가정보보안기본지침」에 따라 CMOS 로그인 비밀번호 정기적 변경, 단말기의 운영체제 및 응용 프로그램에 대한 최신 보안패치 유지, 단말기의 인터넷 파일공유·메신저·대화방 프로그램 등 업무상 불필요한 프로그램의 설치 금지 등 보안대책을 준수하여야 함에도 일부 부서에서 이를 위반한 사실이 확인되었다.

또한, 「국가정보보안기본지침」 및 「USB메모리 등 휴대용 저장매체 보안관리 지침」에 따라 비밀용 휴대용 저장매체(USB)는 비밀자료와 동일하게 이중 캐비닛 또는 금고에 보관하도록 하고 있으나, 개인 서랍에 보관한 사실이 확인되었다.

공단 및 자회사는 시설물 등 안전을 위해 고정형 영상정보처리기기를 운영하면서 「개인정보 보호법」 및 「개인정보보호지침」에 따라 설치 목적 및 장소, 촬영범위 및 시간, 관리책임자의 성명 또는 직책 및 연락처 등의 사항을 기재한 안내판을 설치하여야 하나, 일부 시설에서 관련 법령에 부합하는 안내판이 설치되지 않은 사실이 확인되었다.

그리고 「개인정보 보호법」에 따라 개인정보 처리에 관한 동의를 받을 때는 동의가 필요한 사항과 불필요한 사항을 구분하여야 하는데, 주민등록번호의 경우에는 동의가 아니라 법령 등에 따라 처리하는 사항임에도 동의를 요구하는 서식을 사용 중인 사실이 확인되었다.

또한, 공단과 위수탁 계약을 통해 공무원후생복지시설의 전산시스템 등을 포함한 시설물을 운영 및 관리하는 자회사에서는 「국가정보보안기본지침」에 따라 각종 비밀번호를 사용자 계정과 동일하지 않은 것으로써 숫자·문자·특수문자 등을 혼합하여 안전하게 설정하고, 정기적으로 변경·사용하여야 함에도 이를 준수하지 않은 사실이 확인되었다.

아울러, 공단은 「개인정보의 안전성 확보조치 기준」에 따라 이용자의 개인정보 또는 이용자가 아닌 정보주체의 고유식별정보, 생체인식정보를 업무용 PC(내부망)에 저장할 때는 자동적으로 암호화하여 저장되도록 하고 있는데, 공단의 소관부처인 인사혁신처는 주민등록번호 등 개인정보가 포함된 파일에 대해서는 추가적으로 암호를 설정하여 보관하는 강화된 조치를 요구한 바 있다. 그러나 감사기간 중 공단 및 자회사의 업무용 PC(내부망)를 점검한 결과 주민등록번호 등이 포함된 파일에 대하여 추가적으로 암호를 설정하지 않고 보관 중인 사실이 확인되었다.

## 2. 지적사항 총괄

금번 감사를 통하여 시정 2건, 주의 3건, 권고 1건, 현지조치 1건으로 총 7건의 행정적 조치사항이 도출되었다.

### 〈 지적사항 총괄 〉

| 구 분             |     | 건 수 | 행정상<br>조 치 | 신분상<br>조 치 | 재정상 조치 |                 | 비 고 |
|-----------------|-----|-----|------------|------------|--------|-----------------|-----|
|                 |     |     |            |            | 건수     | 금 액<br>(단위 : 원) |     |
|                 |     |     |            |            |        |                 |     |
| 총 건수(A+B+C)     |     | 7   | 7          | -          | -      | -               | -   |
| 조치<br>요구<br>(A) | 소 계 | 6   | 6          | -          | -      | -               | -   |
|                 | 변 상 | -   | -          | -          | -      | -               | -   |
|                 | 징 계 | -   | -          | -          | -      | -               | -   |
|                 | 시 정 | 2   | 2          | -          | -      | -               | -   |
|                 | 주 의 | 3   | 3          | -          | -      | -               | -   |
|                 | 개 선 | -   | -          | -          | -      | -               | -   |
|                 | 권 고 | 1   | 1          | -          | -      | -               | -   |
|                 | 통 보 | -   | -          | -          | -      | -               | -   |
| 현지조치(B)         |     | 1   | 1          | -          | -      | -               | -   |
| 모범사항(C)         |     | -   | -          | -          | -      | -               | -   |

### 3. 분야별 지적사항 [요약]

#### 1. 개인정보 제3자 제공(목적 외) 후 관리 미흡 : 주의요구

##### (업무개요)

- 공단은 법원, 시군구청 등의 자료요청에 따라 필요한 경우 개인정보의 제3자 제공(목적 외)을 하고 있다.

##### (판단기준)

- 「개인정보보호법」 제18조(개인정보의 목적 외 이용·제공 제한) 제2항에 따르면 개인정보처리자는 정보주체로부터 별도의 동의를 받은 경우 등의 경우에는 정보주체 또는 제3자의 이익을 부당하게 침해할 우려가 있을 때를 제외하고는 개인정보를 목적 외의 용도로 이용하거나 이를 제3자에게 제공할 수 있다.
- 이 때, 공공기관은 개인정보를 목적 외의 용도로 이용하거나 이를 제3자에게 제공한 경우에는 동법 시행령 제15조에 따라 「개인정보 처리 방법에 관한 고시(개인정보보호위원회 고시 제○○○○-○○호)」 별지 제1호 서식의 ‘개인정보의 목적 외 이용 또는 제3자 제공 대장’에 그 내용을 기록하고 관리해야 하며,
- 같은 고시 제2조(공공기관에 의한 개인정보의 목적 외 이용 또는 제3자 제공의 공고)에 따라 정보주체로부터 동의를 받은 경우 외에는 개인정보를 목적 외 이용 등을 한 날부터 30일 이내에 이용 등을 한 날짜, 법적 근거, 목적, 개인정보의 항목(구성)의 사항을 관보 또는 인터넷 홈페이지(10일 이상)에 게재하여야 한다.

##### (문 제 점)

- 감사결과, [표1]과 같이 제3자에게 개인정보를 제공(목적 외)한 이력이 있음에도 관리대장을 작성하지 않거나, 정보주체의 동의를 받지 않았음에도 제3자 제공내용을 인터넷 홈페이지에 게재하지 않은 사실이 확인되었다.

[표1] 개인정보 목적 외 이용 등 관리 현황

| 구분 | 관리대장 작성 | 홈페이지 게시 | 미이행 부서                                       |
|----|---------|---------|----------------------------------------------|
| 1  | ○       | ×       | ◆◆◆◆◆, ♠♠♠♠♠, ♠♠♠♠♠♠♠♠, ♣♣♣♣♣, ♣♣♣♣♣, ○○○○○○ |
| 2  | ×       | ×       | □□□□□□                                       |

(조치할 사항) 향후 유사한 사례가 발생하지 않도록 주의 촉구 (주의)

## 2. 단말기 보안대책 미준수 : 주의요구

### (업무개요)

- 공단 및 자회사 임직원은 「국가정보보안기본지침」에 따라 정보통신망 또는 정보시스템에 대한 접근 또는 사용허가를 받아 단말기(업무용 PC 등)를 사용하고 있다.

### (판단기준)

- 같은 지침 제74조(단말기 보안)에 따라 공단 및 자회사 임직원은 CMOS 로그온 비밀번호의 정기적 변경 사용, 단말기의 운영체제 및 응용프로그램에 대한 최신 보안패치 유지, 인터넷 파일공유·메신저·대화방 프로그램 등 업무상 불필요한 프로그램 설치금지 등 단말기에 대한 보안대책을 준수하여야 한다.

### (문 제 점)

- 공단 및 자회사 임직원의 업무용 PC(인터넷망)를 점검한 결과, [표2]와 같이 단말기 보안대책을 위반한 사실이 확인되었다.

[표2] 단말기 보안대책 위반 현황

| 구분 | 위반내용            | 대상 부서                                              |
|----|-----------------|----------------------------------------------------|
| 1  | CMOS 비밀번호 설정 기준 | ◇◇◇◇◇, △△△△△, ■■■■■■, @@@@, ●●●,<br>=, ♣♣♣, ①①①①①① |
| 2  | 최신 보안패치 유지      | ①①①①①①                                             |
| 3  | 비인가 프로그램 설치 금지  | ■□■□■□■□                                           |

(조치할 사항) 향후 유사한 사례가 발생하지 않도록 주의 촉구 (주의)

## 3. 휴대용 저장매체(비밀용) 보안관리지침 위반 : 주의요구(안)

### (업무개요)

- 공단에서는 업무자료의 보관을 위해서 필요한 경우 「국가정보보안기본지침」에 따라 등록된 휴대용 저장매체를 사용하도록 하고 있다.

### (판단기준)

- 공단은 「국가정보보안기본지침」 제78조 제9항에 따라 국가정보원의 「USB 메모리 등 휴대용 저장매체 보안관리지침」을 준수하여야 하며, 해당 지침 제8조(휴대용 저장매체의 구분 및 관리요령) 제3항 제2호에 따라 비밀용 휴대용 저장매체는 비밀자료와 동일하게 이중 캐비닛 또는 금고에 보관해야 한다.

### (문 제 점)

- 감사기간 중 비밀용 휴대용 저장매체 관리 현황을 점검한 결과, △△△△△에서는 보유 중인 비밀용 휴대용 저장매체를 이중 캐비닛 또는 금고 등에 보관하지 않고 개인 책상 서랍에 보관 중인 사실이 확인되었다.

(조치할 사항) 향후 유사한 사례가 발생하지 않도록 주의 촉구 (주의)



#### 4. 고정형 영상정보처리기기 안내판 설치 미흡 : 시정요구

##### (업무개요)

- 공단 및 자회사는 주요 시설물에 대한 안전 및 화재·범죄 예방 등을 위하여 고정형 영상정보처리기기(CCTV)를 설치하여 운영하고 있다.

##### (판단기준)

- 「개인정보보호법」 제25조 및 공단 「개인정보보호지침」 제51조 등에 따르면 영상정보취급부서장은 정보주체가 영상정보처리기기가 설치·운영 중임을 쉽게 알 수 있도록 설치목적 및 장소, 촬영범위 및 시간, 관리책임자의 성명 또는 직책 및 연락처 등의 사항을 기재한 안내판을 설치하는 등의 조치를 하여야 한다.

##### (문 제 점)

- 공단 및 자회사에서 운영 중인 고정형 영상정보처리기기에 대한 안내판 설치현황을 확인한 결과, [표3]과 같이 일부 시설에서 관련 법령에 부합하는 안내판이 설치되어 있지 않은 사실이 확인되었다.

**[표3] 고정형 영상정보처리기기 운영 안내판 미설치 현황**

| 구 분    | ○○○        | ○○○○○○○○ | ○○○○○○○○○      | ○○○○○○○     |
|--------|------------|----------|----------------|-------------|
| 미설치 구간 | 로비층 옥외 주차장 | 지상 주차장   | ○○○ 내 주차장 등 7곳 | ○○○○○ 식당 내부 |

- (조치할 사항) 관련 기준에 맞게 고정형 영상정보처리기기 안내판 설치조치 (시정)

#### 5. 개인정보 처리 동의서식 부적정 : 시정요구(안)

##### (업무개요)

- 공단은 외부위원 참석수당 지급 등을 위하여 정보주체에게 개인정보 처리의 동의를 받고 있다.

##### (판단기준)

- 「개인정보보호법」 제22조에 따라 공단은 개인정보 수집·이용에 대한 동의를 받을 때, 동의가 필요한 사항과 불필요한 사항을 구분하여야 하는데, 같은 법 제24조 및 제24조의2에 따라 주민등록번호는 법률 등에서 구체적으로 요구하거나 허용한 경우 등에만 처리할 수 있는 바, 정보주체의 동의 사항이 아니므로 정보주체에게 구분하여 안내하여야 한다.

##### (문 제 점)

- 공단이 외부수당 지급 등을 위해 사용하고 있는 개인정보 수집·이용에 대한 동의서식을 검토한 결과, <<<<, >>>>, ♠♠♠♠♠♠♠, ♥♥♥♥♥♥♥에서 주민등록번호 처리에 대한 동의를 불필요하게 요구하는 서식을 사용하고 있음이 확인되었다.

- (조치할 사항) 관련 기준에 맞는 동의서 서식을 사용하도록 시정조치 (시정)

## 6. 비밀번호 관리(외부인 전용 무선랜) 소홀 : 현지조치

### (업무개요)

- 공단 자회사인 〰〰〰〰〰〰〰〰〰은 공단과 위수탁 계약을 통해 공무원후생 복지시설의 전산시스템 등을 포함한 시설물을 운영 및 관리하고 있다.

### (판단기준)

- 「국가정보보안기본지침」 제76조(비밀번호 관리) 제1항 제1호에 따르면 각종 비밀번호를 사용자 계정(아이디)과 동일하지 않은 것으로써 숫자·문자·특수 문자 등을 혼합하여 안전하게 설정하고 정기적으로 변경·사용하여야 한다.

### (문 제 점)

- 〰〰〰〰〰〰의 외부인 전용 무선랜 중계기 관리자 페이지 확인결과, 사용자 계정과 비밀번호가 동일하며, 숫자·문자·특수문자 등으로 혼합하여 설정되어 있지 않은 사실이 확인되었다.

(조치할 사항) 감사기간 중 해당 계정 비밀번호 변경 현지조치 완료 (현지조치)

## 7. 개인정보 안전성 추가 확보 조치 필요 : 권고

### (업무개요)

- 공단은 「개인정보의 안전성 확보조치 기준」 제3조(안전조치의 적용 원칙)에 따라 스스로의 환경에 맞는 개인정보의 안전성 확보에 필요한 조치를 적용하고 있다.

### (판단기준)

- 공단은 이용자의 개인정보 또는 정보주체의 고유식별정보, 생체인식정보를 업무용 PC(내부망)에 저장할 때 자동적으로 암호화하여 저장되도록 함으로써 「개인정보의 안전성 확보조치 기준」 제7조 제5항을 준수하고 있는데, 공단 소관부처인 〰〰〰〰은 이를 강화하여 주민등록번호 등 개인정보가 포함된 파일에는 추가적으로 암호를 설정하도록 요구한 바 있다.

### (문 제 점)

- 공단 및 자회사의 업무용 PC(내부망) 점검 결과, 다수 부서에서 주민등록번호 등이 포함된 개인정보 파일에 추가적으로 암호를 설정하지 않은 사실이 확인되었다.

(조치할 사항) 향후 〰〰〰〰〰 등 외부 지적에 대응할 수 있도록 개인정보 파일에 대해서는 추가적으로 암호 설정 권고 (권고)

4. 지적사항에 대한 처리기준

| 처 분 | 처리기한 | 처 분  | 처리기한 |
|-----|------|------|------|
| 변 상 | 3개월  | 개 선  | 2개월  |
| 징 계 | 1개월  | 권 고  | 2개월  |
| 시 정 | 2개월  | 통 보  | 2개월  |
| 주 의 | 2개월  | 현지조치 | 즉 시  |

### Ⅲ. 감사결과 처분요구 일람표

| 일련<br>번호 | 제<br>목                       | 소관 · 조치부서                                                                                                                                                      | 처분요구<br>등 종류 |
|----------|------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|
| 1        | 개인정보 제3자 제공(목적 외) 후 관리<br>미흡 | ◆◆◆◆◆, □□□□□, ♠♠♠♠♠,<br>♠♠♠♠♠, ♣♣♣♣♣, ♣♣♣♣♣, ○○○○○                                                                                                             | 주 의          |
| 2        | 단말기 보안대책 미준수                 | @@@@@, ●●●, ◇◇◇◇◇, △△△△△,<br>■■■■■, ♣♣♣♣♣, = = = = =,<br>□□□□□, ○○○○○○○, ○○○○○○○○                                                                              | 주 의          |
| 3        | 휴대용 저장매체(비밀용) 보안관리지침<br>위반   | △△△△△                                                                                                                                                          | 주 의          |
| 4        | 고정형 영상정보처리기기 안내판 설치<br>미흡    | ○○○○○○○, ♠♠♠♠♠,<br>■■■■■, ●●●●●●●                                                                                                                              | 시 정          |
| 5        | 개인정보 처리 동의서식 부적정             | ◁◁◁, ▷▷▷▷▷, ♠♠♠♠♠♠♠,<br>♡♡♡♡♡♡♡                                                                                                                                | 시 정          |
| 6        | 비밀번호 관리(외부인 전용 무선랜) 소홀       | ●●●●●●●                                                                                                                                                        | 현지조치         |
| 7        | 개인정보 안전성 추가 확보 조치 필요         | #####, @@@@@, ○○○○○, ◇◇◇◇◇,<br>= = = = =, △△△△△, ▽▽▽▽▽,<br>▶▶▶▶▶, ▼▼▼▼▼, ▷▷▷▷▷,<br>♠♠♠♠♠, ♠♠♠♠♠, ♡♡♡♡♡♡♡,<br>♡♡♡♡♡, ♣♣♣♣♣, ◀◀◀◀◀,<br>□□□□□, ○○○○○○○○, ○○○○○○○○ | 권 고          |

### Ⅳ. 감사결과 처분요구서 : “별첨”

공무원연금공단 상임감사  
주 의 요 구

제 목      개인정보 제3자 제공(목적 외) 후 관리 미흡

소 관 부 서 □□□□□□, ◆◆◆◆◆, ♠♠♠♠, ♠♠♠♠♠♠, ♣♣♣♣, ♣♣♣♣, ○○○○

조 치 부 서 □□□□□□, ◆◆◆◆◆, ♠♠♠♠♠, ♠♠♠♠♠♠♠, ♣♣♣♣♣, ♣♣♣♣♣♣♣, ○○○○○

400

## 1. 업무 개요

공단은 공무원의 ○○사건 등과 관련한 사실조회나 정부 ○○사업 참여 자격 여부 확인 등을 위하여 법원, 관련 시군구청 등에서 요청하는 경우개인정보 제3자 제공(목적 외)을 하고 있다.

## 2. 관계법령 및 내부규정(판단기준)

「개인정보보호법」 제18조(개인정보의 목적 외 이용·제공 제한) 제2항에 따르면 개인정보처리자는 정보주체로부터 별도의 동의를 받은 경우 등의 경우에는 정보주체 또는 제3자의 이익을 부당하게 침해할 우려가 있을 때를 제외하고는 개인정보를 목적 외의 용도로 이용하거나 이를 제3자에게 제공할 수 있다.

이 때, 공공기관은 개인정보를 목적 외의 용도로 이용하거나 이를 제3자에게 제공한 경우 동법 시행령 제15조 및 「개인정보 처리 방법에 관한 고시(개인정보보호위원회 고시 제○○○○-○○호)」 별지 제1호 서식에 따라 ‘개인정보의 목적 외

이용 또는 제3자 제공 대장’에 기록하고 관리해야 하며, 정보주체로부터 별도의 동의를 받은 경우 외에는 같은 고시 제2조(공공기관에 의한 개인정보의 목적 외 이용 또는 제3자 제공의 공고)에 따라 30일 이내에 제공 날짜, 법적 근거, 목적, 개인정보의 항목(구성)의 사항을 관보 또는 인터넷 홈페이지(10일 이상)에 게재하여야 한다.

### 3. 감사결과 확인된 문제점

그런데 감사기간 중 각 부서의 개인정보 목적 외 이용 및 제3자 제공 현황 등을 검토한 결과, [표1]과 같이 제3자에게 개인정보를 제공(목적 외)한 이력이 있음에도 관리대장을 작성하지 않거나, 정보주체로부터 별도의 동의를 받지 않았음에도 제3자 제공(목적 외) 관련 내용을 인터넷 홈페이지에 게재하지 않은 사실이 확인되었다.

[표1] 개인정보 목적 외 이용 등 관리현황

| 구분 | 관리대장 작성 | 홈페이지 게시 | 미이행 부서                            |
|----|---------|---------|-----------------------------------|
| 1  | ○       | ×       | ◆◆◆◆◆, ♠♠♠♠♠, ♣♣♣♣♣, ♣♣♣♣♣, ○○○○○ |
| 2  | ×       | ×       | □□□□□□                            |

※ 자료 : 현장점검 시 제출자료 재구성

그 결과 「개인정보보호법」 제18조(개인정보의 목적 외 이용·제공 제한) 제4항, 같은 법 시행령 제15조(개인정보의 목적 외 이용 또는 제3자 제공의 관리) 등을 위반하는 결과를 초래하였다.

**관련부서 의견**      감사결과에 대하여 별다른 이견을 제기하지 않았으며, 향후 동일한 사례가 발생하지 않도록 관련 법령에 따라 관리대장 작성 및 홈페이지 게재 등을 철저히 하겠다는 의견을 제시하였다.

조치할 사항 이사장(▣▣▣▣▣▣장, ▤▤▤▤▤▤장, ♣♣♣♣♣♣장)께서는 향후  
개인정보 제3자 제공(목적 외) 시 관련 법령에 따른 관리대장 작성 및 홈페이지 게재 등  
절차를 준수할 수 있도록 □□□□□□장, ◆◆◆◆◆장, ♠♠♠♠♠장, ♡♡♡♡♡장,  
♣♣♣♣장, ♣♣♣♣장, ○○○○장에게 주의를 촉구하시기 바랍니다. (주의)

공무원연금공단 상임감사  
주 의 요 구

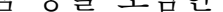
제 목 단말기 보안대책 미준수

소 관 부 서    @@@@, ●●●, △△△△△, ■■■■■■, ◇◇◇◇◇, ══════,  
♣♣♣♣, ▤▤▤▤▤▤▤▤▤▤▤▤▤▤▤▤(□□□□□□□, ○○○○○○○○,  
◐◑◐◑◐◑◐◑◐◑)

조 치 부 서    @@@@,   ●●●,   △△△△△,   ■■■■■■,   ◇◇◇◇◇,   ══════,  
                   ♣♣♣♣

47 0410

## 1. 업무 개요

공단은 「공무원연금법」에 따라 공무원 또는 그 유족의 생활 안정과 복지 향상에 이바지함을 목적으로 연금, 재해보상, 후생복지 등 다양한 서비스를 제공하기 위해 정보통신망 또는 정보시스템을 활용하고 있으며, 자회사인 는 공단과 위수탁 계약을 통해 공무원후생복지시설의 전산시스템 등을 포함한 시설물을 운영 및 관리하고 있다.

## 2. 관계법령 및 내부규정(판단기준)

은 「국가정보보안기본지침(○○○○.○○.○○.)」 제1조 및 제2조에 따른 ‘각급기관’으로 ‘각급기관’의 장으로부터 정보통신망 또는 정보시스템에 대한 접근 또는 사용허가를 받은 임직원은 정보보안 관련 제반 내용을 준수하여야 하며, 的 임직원 또한 상기 지침에 따라 정보보안 관련 제반 규정을 준수하여야 한다.



공단 및 자회사 임직원은 같은 지침 제74조(단말기 보안) 제1항에 따라 단말기 사용과 관련한 일체의 책임을 지며, 같은 조 제2항 각호에 따른 관련 보안대책을 준수하여야 한다. 이 때, 각 호는 아래 [표2]과 같다.

**[표2] 「국가정보보안기본지침」 제74조 제2항 각호**

1. CMOS • 로그인 비밀번호의 정기적 변경 사용
2. 단말기 작업을 일정 시간 중단시 비밀번호 등을 적용한 화면보호 조치
3. 최신 백신 소프트웨어 설치
4. 운영체제 및 응용프로그램에 대한 최신 보안패치 유지
5. 출처, 유통경로 및 제작자가 불분명한 응용프로그램의 사용 금지
6. 인터넷을 통해 자료(파일) 획득시 신뢰할 수 있는 인터넷사이트를 활용하고 자료(파일) 다운로드시 최신 백신 소프트웨어로 검사 후 활용
7. 인터넷 파일공유 • 메신저 • 대화방 프로그램 등 업무상 불필요한 프로그램의 설치 금지 및 공유 폴더 삭제
8. 웹 브라우저를 통해 서명되지 않은 액티브-X 등이 다운로드 • 실행되지 않도록 보안 설정
9. 내부망과 기관 인터넷망이 분리된 기관의 인터넷 PC에서는 각급기관의 장이 정한 특별한 사유가 없는 한 문서프로그램을 읽기 전용(專用)으로 운용
10. 그 밖에 국가정보원장이 안전성을 확인하여 배포한 프로그램의 운용 및 보안권고문 이행

### 3. 감사결과 확인된 문제점

그런데 감사기간 중 각 부서의 개인 업무용(인터넷망) PC를 점검한 결과 아래 [표3]과 같이 단말기 보안대책을 준수하지 않고 있음이 확인되었다.

**[표3] 단말기 보안대책 위반 현황**

| 위반내용                 |                               | 대상 부서                                |
|----------------------|-------------------------------|--------------------------------------|
| CMOS 비밀번호의 정기적 변경 사용 | CMOS 비밀번호 미설정                 | @ @ @ @ @, ♣♣♣♣, ○●○●○●○●            |
|                      | CMOS 초기 비밀번호 사용               | ◇◇◇◇◇◇, △△△△△△, ■■■■■■■■, ●●●, ===== |
| 운영체제의 최신 보안패치 유지     | 서비스 종료된 Window 7 사용 (방화벽 미설치) | ○ ○ ○ ○ ○ ○ ○ ○                      |
| 업무상 불필요한 프로그램 설치금지   | 비인가 프로그램(카카오톡) 사용             | ■ ■ ■ ■ ■ ■ ■ ■                      |

※ 자료 : 현장점검 시 제출자료 재구성

그 결과, 단말기를 통한 정보 유출 등이 발생할 수 있는 결과를 초래하였다.

관련부서 의견      감사결과에 대하여 별다른 이견을 제기하지 않았으며, 향후 동일한 사례가 발생하지 않도록 관련 법령에 따라 관련 지침을 준수한 CMOS 비밀번호 주기적 변경, 최신 보안패치 유지, 비인가 프로그램 설치 금지 등을 철저히 하겠다는 의견을 제시하였다.

조치할 사항 이사장(▨▨▨▨▨▨장, ▩▩▩▩▩▩장. ▪▪▪▪▪▪장, ♣♣♣♣♣♣장)께서는 향후 단말기 보안과 관련하여 CMOS 등 비밀번호 주기적 변경, 최신 보안 패치 유지 및 비인가 프로그램 설치 금지 등 단말기 보안이 철저히 이뤄질 수 있도록 @@@@@장, ●●●장, △△△△△장, ■■■■■장, ◇◇◇◇◇장, =====장, ♣♣♣♣장에게 주의를 촉구하시고 이사장(◇◇◇◇◇장)께서는 단말기 보안을 준수하는 등 향후 동일한 사례가 발생하지 않도록 ▯▯▯▯▯▯▯▯▯▯▯▯▯▯▯▯ 대표이사에게 주의를 촉구하시기 바랍니다. (주의)

# 공무원연금공단 상임감사

## 주 의 요 구

제 목 휴대용 저장매체(비밀용) 보안관리지침 위반

소 관 부 서 △△△△△

조 치 부 서 △△△△△

내 용

### 1. 업무 개요

공단은 휴대용 저장매체와 관련한 정보 유출 등의 사고를 막기 위해서 휴대용 저장매체를 사용할 경우에는 「국가정보보안기본지침(○○○○.○○.○○)」, 「USB 메모리 등 휴대용 저장매체 보안관리지침」 및 공단 「휴대용 저장매체 보안관리 매뉴얼」 등에 따라 사전 승인을 득한 후 사용하도록 하고 있다.

### 2. 관계법령 및 내부규정(판단기준)

공단 임직원은 USB메모리 등 휴대용 저장매체를 사용하고자 하는 경우, 「국가정보보안기본지침」 제78조(휴대용 저장매체 보안) 제9항에 따라 국가정보원장이 배포한 「USB메모리 등 휴대용 저장매체 보안관리지침」을 준수하여야 하며, 비밀용 휴대용 저장매체의 경우에는 같은 지침 제8조(휴대용 저장매체의 구분 및 관리요령) 제3항 제2호에 따라 비밀자료와 동일하게 이중 캐비닛 또는 금고에 보관하여야 한다.

### 3. 감사결과 확인된 문제점

그런데, 감사기간 중 각 부서에서 보유 중인 비밀용 휴대용 저장매체 관리 현황을 점검한 결과, 아래 [그림1]과 같이 △△△△△에서 이중 캐비닛 또는 금고 등에 보관하지 않고 개인 책상 서랍에 보관 중인 사실이 확인되었다.

[그림1] 휴대용 저장매체 보안관리지침 위반 현황(△△△△△)



※ 자료 : 감사기간 중 감사인 직접 촬영

그 결과, 「국가정보보안기본지침」 제78조(휴대용 저장매체 보안) 등을 위반하는 결과를 초래하였다.

관련부서 의견      감사결과에 대하여 별다른 이견은 제기하지 않았다.

조치할 사항      이사장(■■■■■■■■장)께서는 비밀용 휴대용 저장매체가 관련 지침에 따라 이중 캐비닛 또는 금고에 보관될 수 있도록 △△△△△장에게 주의를 촉구하시기 바랍니다. (주의)

공무원연금공단 상임감사  
시 정 요 구

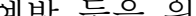
제 목 고정형 영상정보처리기기 안내판 설치 미흡

**소 관 부 서**

[illegible]

내                  옹

## 1. 업무 개요

공단은 안전 및 화재·범죄 예방 등을 위하여  및  내에 영상정보처리기기(CCTV)를 설치하여 운영하고 있으며, 공단으로부터 공무원복지시설 전반에 대한 운영을 위탁받아 운영하고 있는 는 , , ,  등 주요시설물의 안전 및 화재·범죄 예방 등을 위하여 영상정보처리기기(CCTV)를 설치하여 운영하고 있다.

## 2. 관계법령 및 내부규정(판단기준)

「개인정보보호법」 제25조(고정형 영상정보처리기기의 설치·운영 제한), 같은 법 시행령 제24조(안내판의 설치 등) 및 공단 「개인정보보호지침」 제51조(안내판의 설치)에 따르면 영상정보취급부서장은 정보주체가 영상정보처리기기가 설치·운영 중임을 쉽게 알 수 있도록 설치목적 및 장소, 촬영범위 및 시간, 관리책임자의 성명 또는 직책 및 연락처 등의 사항을 기재하여 안내판을 설치하는 등의 필요한 조치를 하여야 한다.

### 3. 감사결과 확인된 문제점

그런데, 감사기간 중 공단 및 자회사에서 운영 중인 주요 시설물의 고정형 영상정보처리기기 안내판 설치 현황을 확인한 결과, [표3]과 같이 관련 법령에 부합하는 안내판이 설치되어 있지 않은 사실이 확인되었다.

[표4] 고정형 영상정보처리기기 운영 안내판 미설치 현황

| 구 분    |  |  |  |  |
|--------|-----------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| 현 황    |  |  |  |  |
| 미설치 구간 | 로비층 옥외 주차장                                                                        | 지상 주차장                                                                            | ○○○ 내 주차장 등 7곳                                                                     | ○○○○○ 식당 내                                                                          |

※ 자료 : 감사기간 중 감사인 직접 촬영

그 결과, 「개인정보보호법」 시행령 제24조(안내판의 설치 등) 등을 위반하는 결과를 초래하였다.

**관련부서 의견** 감사결과에 대하여 별다른 이견은 제기하지 않았으며, 관련 법령을 준수하여 고정형 영상정보처리기기 운영 관련 안내판을 설치하겠다는 의견을 제시하였다.

**조치할 사항** 이사장()장, 장) 및   
대표이사께서는 , , ,  내 관련 법령을 준수한 고정형 영상정보처리기기 운영 관련 안내판이 설치될 수 있도록 조치하여 주시기 바랍니다. (시정)

# 공무원연금공단 상임감사 시 정 요 구

|         |                            |
|---------|----------------------------|
| 제 목     | 개인정보 처리 동의서식 부적정           |
| 소 관 부 서 | ◁◁◁, ▷▷▷▷▷, ♠♠♠♠♠♠, ♥♥♥♥♥♥ |
| 조 치 부 서 | ◁◁◁, ▷▷▷▷▷, ♠♠♠♠♠♠, ♥♥♥♥♥♥ |

## 내 용

### 1. 업무 개요

공단에서는 각종 공모전, 심의회 등에 참석한 외부위원의 수당 지급, 사회공헌 담당자 워크숍 강사료 지급 등을 위하여 개인정보 수집·이용 동의 절차를 이행하고 있다.

### 2. 관계법령 및 내부규정(판단기준)

공단은 「개인정보보호법」 제15조(개인정보의 수집·이용), 제22조(동의를 받는 방법) 등에 따라 외부위원 참석수당 지급 등을 위하여 개인정보 수집·이용에 대한 동의를 받는 경우 정보주체의 선택에 혼란을 초래하지 않도록 제22조 제3항에 따라 동의가 필요한 사항과 불필요한 사항을 구분하여 요구하여야 한다.

이 때, 주민등록번호는 같은 법 제24조(고유식별정보) 제1항 제2호 및 제24조의2(주민등록번호 처리의 제한) 제1항에 따라 법률 등에서 구체적으로 요구하거나 허용한 경우에만 처리가 가능한 사항으로 동의가 필요한 사항과 구분된다.

### 3. 감사결과 확인된 문제점

그런데, 감사기간 중 각 부서에서 수당 지급 등을 위하여 사용하고 있는 개인정보 수집·이용에 대한 동의 서식을 확인한 결과, [표5]와 같이 법령에 따라 처리하는 주민등록번호에 대하여 동의를 불필요하게 요구하는 서식을 사용한 사실이 확인되었다.

**[표5] 개인정보 처리 동의 서식 운영 미흡 현황**

| 구 분 | 부서명    | 서식 내용                           | 비 고                                   |
|-----|--------|---------------------------------|---------------------------------------|
| 1   | ◁◁◁    | 2024 상록아파트 사진 공모전 작품 심사위원 수당 지급 | 소득세법 등 관련 법령에 따라 주민등록번호 처리 (동의 대상 아님) |
| 2   | ▷▷▷▷▷  | 사회공헌 담당자 워크숍 감사료 지급             |                                       |
| 3   | ♠♠♠♠♠♠ | 연금아카데미 교육 감사료 지급                |                                       |
| 4   | ♡♡♡♡♡♡ | 연금아카데미 교육 감사료 지급                |                                       |

※ 자료 : 현장점검 시 제출자료 재구성

그 결과, 「개인정보보호법」 제22조(동의를 받는 방법) 제3항과 달리 정보주체 선택에 혼란을 야기하는 결과를 초래하였다.

**관련부서 의견** 감사결과에 대하여 별다른 이견을 제기하지 않았다.

**조치할 사항** 이사장(♠♠♠♠♠♠장)께서는 관련 법령에 따라 동의가 불필요한 사항에 대하여 동의를 요구하는 서식을 사용하지 않고, 외부위원 수당 지급 등 개인정보 수집·이용 동의 서식을 활용할 시에 관련 법령을 준수한 양식을 사용할 수 있도록 조치하여 주시기 바랍니다. (시정)



# 공무원연금공단 상임감사 현 지 조 치

제 목 비밀번호 관리(외부인 전용 무선랜) 소홀  
소 관 부 서 [REDACTED] (●●●●●●●●)  
조 치 부 서 [REDACTED]  
내 용

## 1. 업무 개요

공단은 「공무원연금법」 제78조(기금의 출연과 출자)에 따라 공무원 후생복지 시설의 운영을 위하여 자회사인 [REDACTED]를 설립하고, [REDACTED]는 「공무원 후생복지시설 관리운영 위·수탁 용역계약」을 통해 공무원 후생복지시설의 전산시스템 등을 포함한 시설물을 운영 및 관리하고 있다.

## 2. 관계법령 및 내부규정(판단기준)

자회사인 [REDACTED]의 임직원은 「국가정보보안기본지침」 제76조 (비밀번호 관리) 제1항 제1호에 따라 각종 비밀번호를 사용자 계정(아이디)과 동일하지 않은 것으로써 숫자·문자·특수문자 등을 혼합하여 안전하게 설정하고 정기적으로 변경·사용하여야 한다.

## 3. 감사결과 확인된 문제점 및 조치결과

그런데, 감사기간 중 [REDACTED]에서 운영 및 관리하는 사업장 중 하나인 ●●●●●●●●에서 외부인 전용 무선랜의 중계기(AP)의 관리자 페이지 사용자 계정과

비밀번호가 초기 설정 비밀번호와 동일한 것으로 확인되어, 감사기간 중 아래 [표5]와 같이 해당 지침에 부합하도록 비밀번호 변경 처리를 완료하였다.

[표5] 00000000 외부인 전용 무선랜 중계기 비밀번호 관리 소홀 현지조치 결과

| 구 분 | (당초) 비밀번호 설정                                                                      | (당초) 비밀번호 설정                                                                      | (변경) 비밀번호 재설정                                                                      | (변경) 비밀번호 재설정 완료                                                                    |
|-----|-----------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| 현 황 |  |  |  |  |
| 내 용 | 초기설정 암호 사용                                                                        | 로그인 화면(초기 비밀번호 사용)                                                                | 비밀번호 변경 설정 중                                                                       | 로그인 화면(비밀번호 설정완료 후)                                                                 |

※ 자료 : 00000000 제출자료 재구성

관련부서 의견      감사결과에 대하여 별다른 이견을 제기하지 않으며, 향후 유사한 사례가 발생하지 않도록 관련 지침에 따라 철저히 관리하겠다는 의견을 제시하였다.



○○○○○○○○)을 운영하고 있으며, 이 과정에서 방문고객의 신분확인 등을 위하여 개인정보를 취급하고 있다.

## 2. 관계법령 및 내부규정(판단기준)

「개인정보보호법」 제29조(안전조치의무), 같은 법 시행령 제30조(개인정보의 안전성 확보 조치) 및 「개인정보의 안전성 확보조치 기준(개인정보보호위원회 고시 제○○○○○-○○호)」 제3조(안전조치의 적용 원칙)에 따라 개인정보처리자<sup>1)</sup>는 처리하는 개인정보의 보유 수, 유형 및 정보주체에게 미치는 영향 등을 고려하여 스스로의 환경에 맞는 개인정보의 안전성 확보에 필요한 조치를 적용하여야 한다. 이에 개인정보처리자인 공단은 같은 기준 제7조(개인정보의 암호화) 제5항에 따라 이용자의 개인정보 또는 이용자가 아닌 정보주체의 고유식별정보, 생체인식정보를 업무용 PC(내부망)에 저장할 때 DRM(Digital Right Management) 방식<sup>2)</sup>으로 조직 내부에서 생성되는 다양한 종류의 파일 및 개인정보 파일이 자동으로 암호화하여 저장되도록 하고 있다.

이와 관련하여, 공단의 소관부처인 ○○○○○○에서는 ○○○○년도 정기 보안감사를 실시(○○○○.○○.○○.)하면서 주민등록번호 등 개인정보가 포함된 파일에 대해서는 추가적으로 암호를 설정하여 보관할 것을 요구하고 이를 지적한 바 있다.(○○○○○○○ ○○○○○○-○○○○○○ '○○.○○.○○) 따라서, 공단은 개인정보의 안전성 확보조치를 강화하여 ○○○○○○ 등 외부 지적에 대응할 수 있도록 주민등록번호 등 개인정보가 포함된 파일에 대해서는 추가적으로 암호를 설정하여 보관할 필요가 있다.

1) 업무를 목적으로 개인정보파일을 운용하기 위하여 스스로 또는 다른 사람을 통하여 개인정보를 처리하는 공공기관, 법인, 단체 및 개인 등(「개인정보보호법」 제2조 제5호)

2) 조직 내부에서 생성되는 전자문서를 암호화하고 해당 문서를 접근 및 사용할 수 있는 권한을 지정함으로써 허가된 사용자만 중요 문서(개인정보 문서, 기밀문서 등)를 사용하게 하는 기술(「개인정보의 암호화 조치 안내서(개인정보보호위원회)」, ○○○○.○○)

